

OWASP Top 10: The Threat Menu

The OWASP Top 10 is a periodically updated list of the most critical web app security risks. It is not a complete list – it is the "you must know these now" list.

The 2021 edition (summary)

A01:2021-Broken Access Control – users doing more than allowed (IDOR, missing authz checks)

A02:2021-Cryptographic Failures – sensitive data exposed (no TLS, weak hashing, hardcoded keys)

A03:2021-Injection – SQL/NoSQL/LDAP/OS/command injection

A04:2021-Insecure Design – missing threat modeling, rate limits, business logic gaps

A05:2021-Security Misconfiguration – default creds, verbose errors, unpatched components (was A05 too)

A06:2021-Vulnerable and Outdated Components – known CVEs in libraries

A07:2021-Identification and Authentication Failures – weak passwords, session flaws, no MFA

A08:2021-Software and Data Integrity Failures – insecure deserialization, untrusted CI/CD, signed artifacts

A09:2021-Security Logging and Monitoring Failures – no logs, no alerting

A10:2021-Server-Side Request Forgery (SSRF) – server fetches attacker-controlled URLs

Attackers exploit: Broken Access Control -> IDOR is #1 in real data

What defenders underuse: logging & monitoring (A09)

How to use it

Not a checklist to "pass" – a **risk lens** for design reviews and tests
The detailed risks (e.g., the full injection page) are the real depth
Combine with OWASP ASVS for a strong verification standard
Pair with the OWASP Testing Guide for actual attack steps

Industry data consistently shows Broken Access Control and Cryptographic Failures at the top of breaches. When auditing any app, start there.

[← Module start](#)

[Secure Coding: Injection, XSS,...](#)